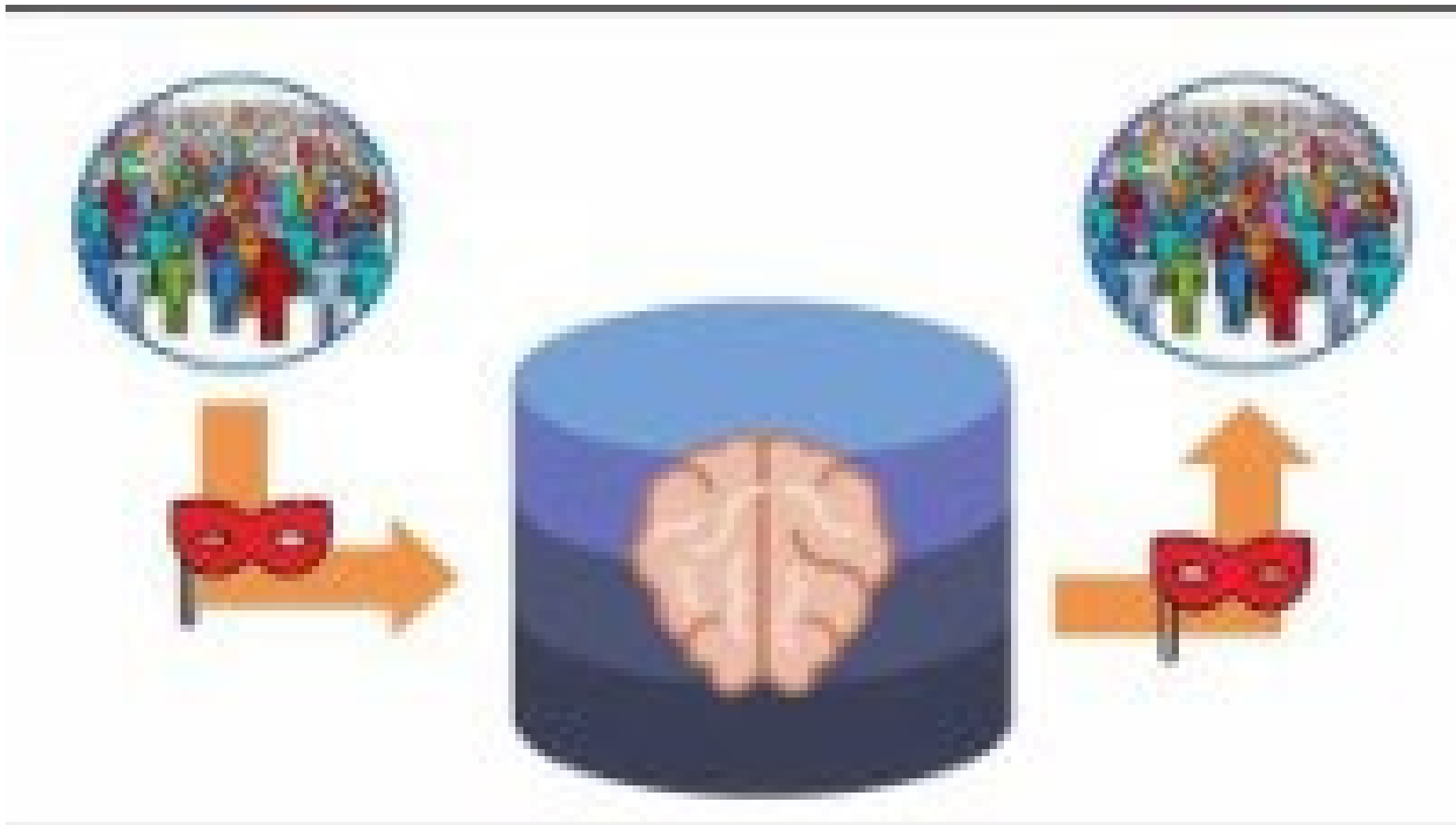


Introduction to Database Security

Lecture 1

Topics

- 1) Threat Modelling
- 2) Compliance Considerations



https://www.youtube.com/watch?v=wAEL5RnX_Yc

Threat Analysis and Compliance

Introduction

- ▶ Explore how to model threats so we can identify, understand and prioritize risk.
- ▶ This will lead to proper high-level countermeasures.
- ▶ Introduce compliance and potential impacts to the SQL server security model.
- ▶ In this course, we will be securing SQL Server.
- ▶ Lecture - Securing.
- ▶ Tutorial - attacking.

Introduction

White, gray and black hat comparison



WHITE HAT

Considered the good guys because they follow the rules when it comes to hacking into systems without permission and obeying responsible disclosure laws



GRAY HAT

May have good intentions, but might not disclose flaws for immediate fixes

.....

Prioritize their own perception of right versus wrong over what the law might say



BLACK HAT

Considered cybercriminals; they don't lose sleep over whether or not something is illegal or wrong

.....

Exploit security flaws for personal or political gain—or for fun

Threat Modelling

Part 1

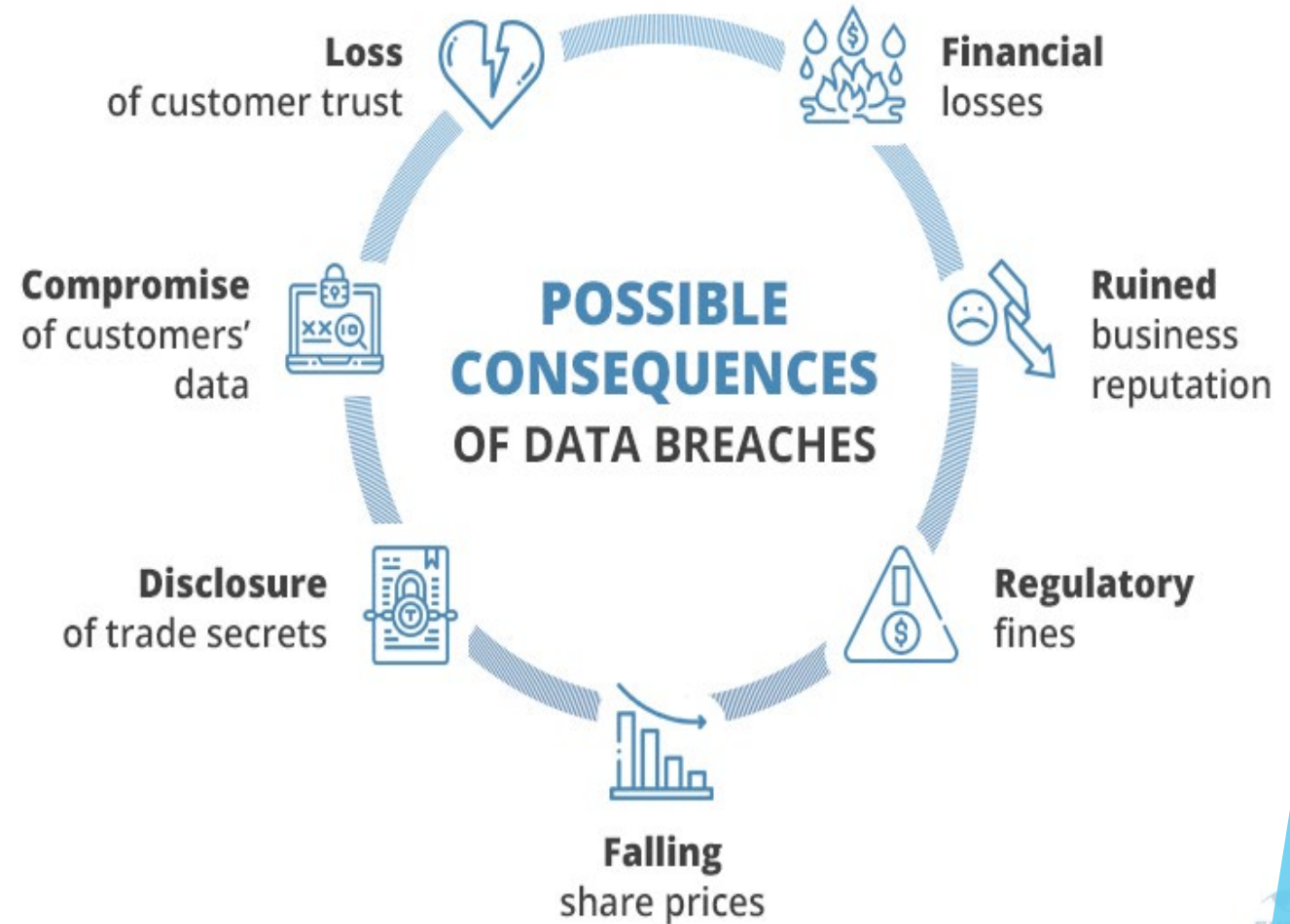
Threats to Databases

- ▶ All type of RDBMS are subject to threats such as
 - ▶ SQL Injection attacks
 - ▶ Brute force on the system admin account on Port 1433.
 - Most times this is not disabled or a client requires it.
 - ▶ Insider attacks → external attacks.

Use threat modelling to determine threat priority and countermeasures.

Let's Discuss

What are the consequences of these security attacks?



Threat Modelling

- ▶ Threat modelling: *Understanding threats to a data-tier application and then classify and rate the threats that have been discovered, in order to determine the most critical to address.*
- ▶ Threat modelling should be carried out during design phase and at least at the testing phase. Compare with Enterprise standards and policies.

Note: countermeasures is not part of threat modelling.

Threat Modelling

Six Steps of Threat Modelling

- 1) Identifying assets
- 2) Creating an architecture overview
- 3) Building a security profile
- 4) Identifying the threats
- 5) Documenting the threats
- 6) Rating and prioritizing the threats

We will be focusing on an application called CarterSecureSafe, which belongs to the fictional company CarterSecurityTools.com and consists of a simple Web application, where customers can shop for security software. The back end of the Web application is a database hosted in a SQL Server instance

Step 1: Identifying Assets

- ▶ Assets in terms of DBAs would be sensitive data.
- ▶ Identifying company confidential information that would have a potential commercial impact if stolen.
- ▶ E.g. customer data, corporate secrets, financial data
- ▶ Consequences of loss include loss of morale, business reputation, fines, loss of customers to competitors.

Step 1: Identifying Assets

Sensitive Information can be broken into three categories:

High-Risk

- Data that could be used to steal an individual's identity or cause harm to the individual, and for which there are legal requirements or industry standards prohibiting or imposing financial penalties for unauthorized disclosure.

Restricted

- Information assets for which there are legal requirements prohibiting or imposing financial penalties for unauthorized disclosure.

Confidential

- Data that the organization has determined should be protected because it may expose the organization to loss if disclosed but is not protected legally.

Lets Discuss

Identify the sensitive data of MMU students in MMU Academic Management System.

- Student ID
- Courses taken
- Number of course units enrolled
- Schedule
- Last school attended
- Test scores
- Advising records
- Educational services received
- Disciplinary actions
- Student e-mail
- Grades and/or grade point average

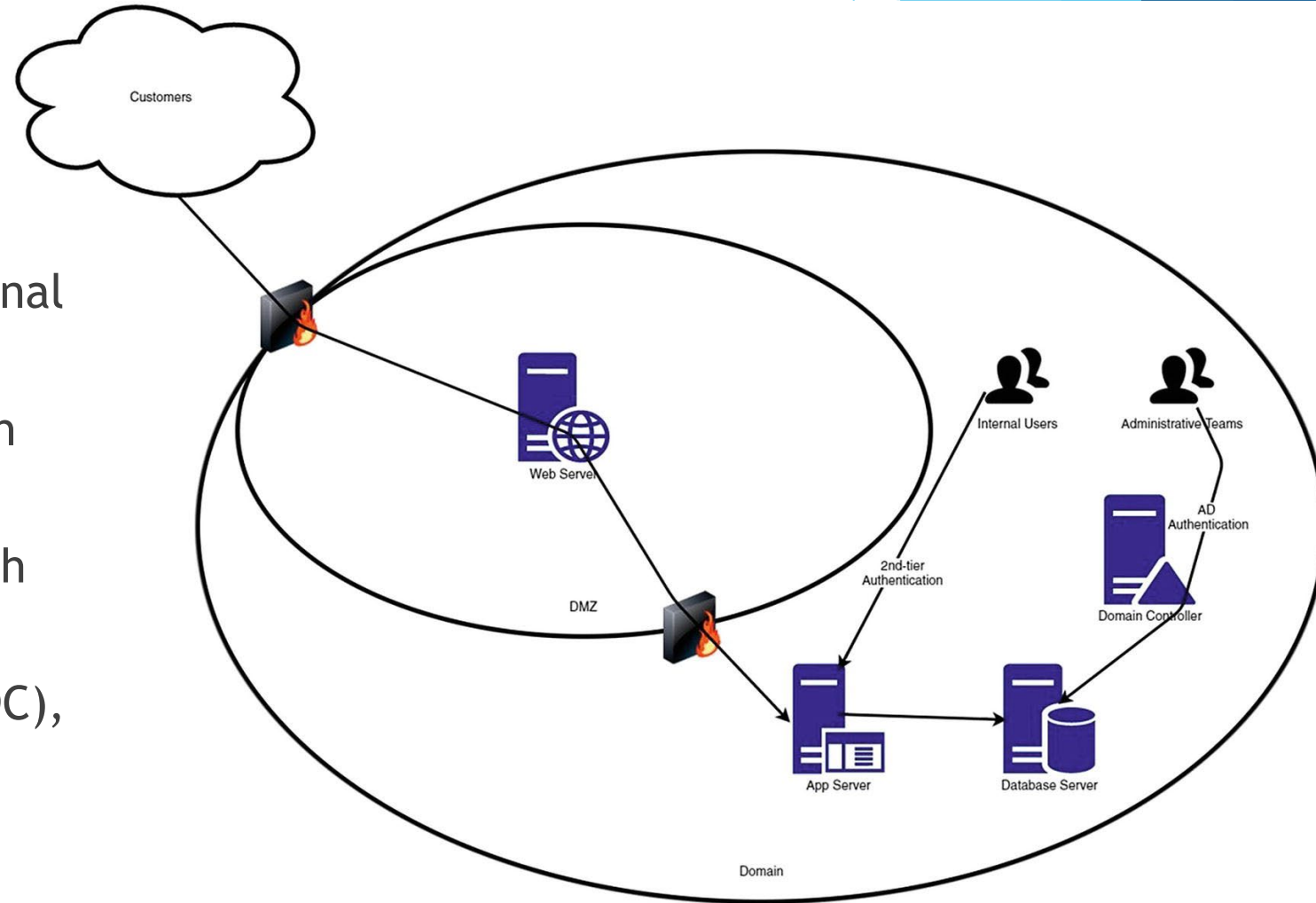
Step 2: Creating an Architecture Overview

- Define logical architecture of applications in diagrammatic form.
- Identify end-to-end applications that are potentially vulnerable.
- Identify technology specific vulnerabilities.
- Two sub steps involved in this step:
 - 1) Creating infrastructure components
 - 2) Identifying the technology stack

Step 2: Creating an Architecture Overview

1. Create Infrastructure Components

- ▶ Diagram shows CarterSecureSafe's application structure.
- ▶ Consists of both internal and external users
- ▶ Internal users authenticate through Active Directory
- ▶ External users authenticate through Web Server in DMZ(Demilitarised).
- ▶ Also present: Domain Controller (DC), firewalls



Step 2: Creating an Architecture Overview

2. Identify the Technology Stack

- ▶ DBAs need a holistic view of application and platform to secure data-tier applications appropriately.
- ▶ Table 1-1 lists the implementations for CarterSecureSafe application

Step 2: Creating an Architecture Overview

Table 1-1. Technology Implementations

Technology	Topology Component	Details
Active Directory (AD)	Authentication	Used to authenticate internal users and administrative teams
Domain Controller (DC)	Authentication	Server used by AD to authenticate users
Demilitarized Zone (DMZ)	Networking	Subnet that exposes external-facing services
Domain	Networking	A logical container of users, groups, workstations, servers, and other objects, whose authentication is controlled by a Domain Controller
IIS	Web Server	Used to authenticate external users and pass traffic to the application server
.NET	Core Application & Authentication	The core web application has been built using the .NET framework. It also provides forms authentication for internal users.
SQL Server 2016	Database Tier	The databases that drive the application are stored and managed on a SQL Server 2016 instance.
IPsec	Cryptography	Data is encrypted in transit, between the application and database server, using IPsec.
HTTPS	Protocol	External users access the web application via HTTPS.

Step 3: Building a Security Profile

- ▶ Identify **data flows** to define trust boundaries and entry points.
- ▶ CarterSecureSafe has two distinct flows of data:
 - 1) Internet users who order items from the store
 - 2) Internal users who update orders and perform administration
- ▶ Hence there are two clear data paths:
 - 1) For customers: from the internet to the web server (customer entry point), through the application server and to the SQL server.
 - 2) For internal users: application server (user entry point) into the SQL server through internal network.
 - 3) A third entry point are for DBAs who connect directly to the SQL server.
- ▶ These trust boundaries are mapped to firewalls. Customers have to go through perimeter and internal firewalls, whereas internal data paths remain within the internal trust boundary.

Step 3: Building a Security Profile

- ▶ Once the application is decomposed, a security profile can be established.
- ▶ DBAs perspective will focus on elements directly interfacing with the database.
- ▶ Table 1-2 shows the security profile for CarterSecureSafe application.

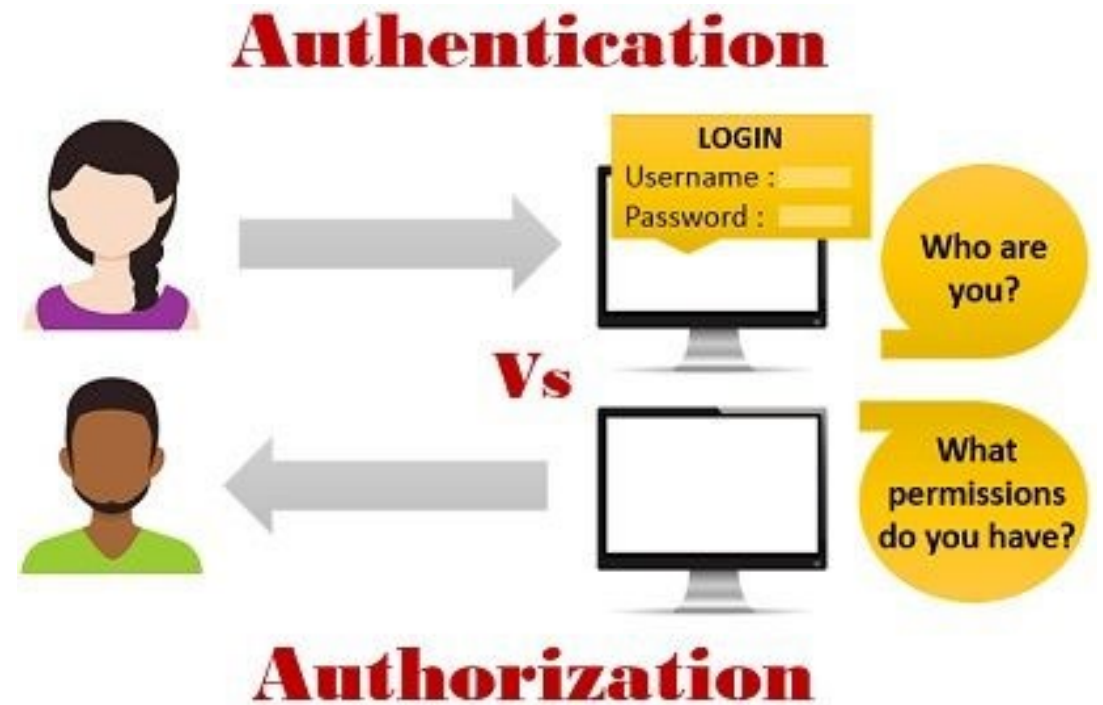
Table 1-2. Security Profile

Profile Element	Considerations
Input Validation	The application runs ad-hoc T-SQL, as opposed to calling stored procedures. Therefore, the input cannot easily be validated at the SQL Server level.* As the main entry point is the web server, trust boundaries are crossed, and the input cannot be trusted.
Authentication	Users authenticate to the database engine via 2nd-tier authentication. No domain authentication is required to access the databases. Penetration testing to ensure that the sa account has been either disabled or renamed has not been carried out on the instance. The application server resolves user credentials. The application server uses a single user to authenticate to the database engine.
Cryptography	Data is encrypted in transit using IPsec. Databases are not encrypted using TDE (Transparent Data Encryption). No column level encryption is used.
Auditing	SQL Audit has not been configured; however, the default trace is running, which will capture a limited subset of activity, such as creating new objects or dropping existing objects.

**There may be (and should be) input validation on the application side, but the DBA is unlikely to have visibility of this.*

Lets Discuss

What is the difference between authentication and authorization?





Step 4: Identifying Threats

- ▶ Threat identification usually involves a penetration test.
- ▶ Pentest tools include: Qualys, Metasploit, Kali
- ▶ Organize threats using STRIDE -

S - Spoofing Identity: steal another user's identity and use to authenticate

T - Tampering with data: maliciously modifying data

R - Repudiation: an malicious user's ability to hide or deny their activity

I - Information disclosure: force a system to reveal more than permissioned

D - Denial of service (DoS): flooding a system to take it down

E - Elevation of privileges: exploit to gain more permissions than intended

Step 5: Documenting Threats

- ▶ Also use STRIDE to document threats.
- ▶ Table 1-3 shows the example for CarterSecureSafe application.

Table 1-3. STRIDE Classification

Risk	Category	Example
SQL Injection	S,T,I	Attacker types ' OR 1=1-- In password field of the website to spoof the first user identity stored in the users table.
DoS	D	Attacker uses robots to simultaneously flood the database with resource-intensive requests.
Stealing sa account credentials	E	An attacker suspects that the sa account has not been disabled or renamed. Therefore, an attack is launched against the password of the sa account.
DBA performs malicious action	R	A privileged user performs a malicious action and the attack cannot be proven, due to lack of auditing.
SQL Server Remote Code Execution Vulnerability*	S,T	An attacker runs a malicious query to exploit a vulnerability in SQL Server, where the use of uninitialized memory in some virtual functions is permitted.

**At the time of writing, Microsoft had not released any security bulletins relating to SQL Server 2016. The vulnerability used as an example applies to SQL Server versions 2008-2014.*



Step 6: Rating and Prioritizing Threats

- ▶ Rate threats based on probability of attacks occurring and damage incurred if threat realized.
- ▶ Methodologies include:
 - 1) Simplest: High-medium-low
 - 2) Scientific: Critical-Important-Moderate-Low
 - 3) Quantitative: Damage potential*probability formula
 - 4) DREAD



Step 6: Rating and Prioritizing Threats

Using DREAD: all ratings are 1 to 10.

Character	Acronym for	Rating
D	Damage potential	1 for minimal damage, 10 indicates a catastrophic vulnerability
R	Reproducibility	1 is almost impossible to reproduce, 10 is very easy to reproduce, more likelihood of automated attacks like Bots.
E	Exploitability	1 Indicates a vulnerability is difficult to exploit. 10 is easily exploitable.
A	Affected Users	Take the percentage of users affected and divide by 10 and round to nearest whole number. E.g. if 80% of users affected, the rating is 8. For 25% the rating is 3.
D	Discoverability	1 for obscure vulnerabilities. 10 is easily discovered, such as SQL injection

Step 6: Rating and Prioritizing Threats

- ▶ Rate each threat according to DREAD categories. Then sum the ratings and divide by the number of threats, round to nearest number. This will give overall DREAD rating for each threat.
- ▶ Table 1-4 show DREAD rating for CarterSecureSafe.

Table 1-4. DREAD Ratings

Risk	Category (STRIDE)	D	R	E	A	D	Threat Rating
SQL Injection	S,T,I	10	10	9	10	10	10
DoS	D	10	10	10	10	10	10
Stealing sa account credentials	E	6	10	8	10	10	9
DBA performs malicious action	R	10	1	1	10	10	6
SQL Server Remote Code Execution Vulnerability	S,T	8	5	5	6	1	5

Countermeasures

Put countermeasures for each threat that has been identified, beginning with highest rating.

- ▶ SQL injection - input validation
- ▶ DOS - ensure database is not in DMZ and not exposed to Internet, implement Resource Governor.
- ▶ Stealing SA credentials - disable or rename SA account, introduce SQL Server Audit
- ▶ DBA performs malicious action - have a rep strategy in place, SQL Server Audit
- ▶ SQL Server Remote Code Execution Vulnerability - threat low so no immediate action for now. Log risk in risk register and patch.

Compliance

Part 2

SOX for SQL Server

- ▶ Sarbanes-Oxley Act was passed in 2002 as a response to Enron scandal.
- ▶ Ensures financial accuracy in companies and avoid corruption.
- ▶ Applies to all public companies in US and some aspects involve private ones as well.
- ▶ However, SOX was written from a business perspective, so can be confusing for technologists.
- ▶ A few key points:
 - 1) Auditing - critical data access, user permissions, data structure changes, access failures.
 - 2) Clear separation of duties between DBA and developers
 - 3) Implementation, documentation and enforcement of controls for database management processes

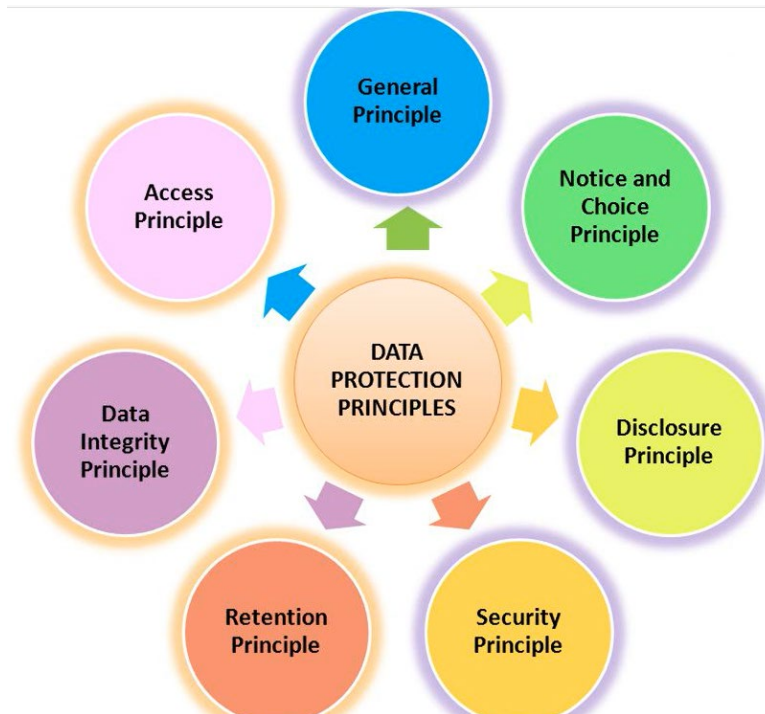
GDPR for SQL Server

- ▶ Came into force in EU in 2018
- ▶ Intention: ensure data privacy of EU residents and giving them control over the data that is held about them.
- ▶ Broad legislation.
- ▶ Max: 20mil Euros or 4% of global turnover in fines.
- ▶ Data must be protected by design and by default - must have control over who has access to data.
- ▶ A few aspects to consider:
 - 1) Authentication
 - 2) Secure processing and encryption
 - 3) Audit records of data processing
 - 4) Risk assessment and demonstrate compliance with GDPR

Lets Discuss

What is PDPA?

The Personal Data Protection Act 2010 (“PDPA”) is **an Act that regulates the processing of personal data regarding commercial transactions.** It was gazette in June 2010. The penalty for non-compliance is between RM100k to 500k and/or between 1 to 3 years imprisonment.



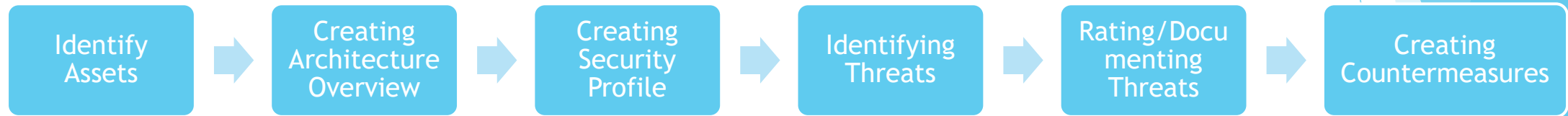
Malaysia

Personal Data Protection Act 2010

- Data Protection Principles
- Rights of Data Subjects
- Special entity to enforce the Act (Data Protection Commissioner)
- No mandatory data breach notification.
- Differentiate personal data & sensitive data.
- Does not apply to Federal and States Governments

Summary

Threat analysis



Identifying Threats: STRIDE methodology

Rating Threats: DREAD methodology

Compliance - SOX (US), GDPR (Europe)

Setting Up MS-SQL

- ▶ Download and install SQL Server (Developer) from <https://www.microsoft.com/en-us/sql-server/sql-server-downloads>
- ▶ Download and install SQL Server Management Studio from <https://docs.microsoft.com/en-us/sql/ssms/download-sql-server-management-studio-ssms?view=sql-server-ver15>
- ▶ Download WideWorldImporters database from <https://docs.microsoft.com/en-us/sql/samples/wide-world-importers-dw-install-configure?view=sql-server-ver15>